

GrounUp Enterprise Specification

Phase 28 - Enterprise Security, Identity, Zero Trust, Privacy, Audit & Threat Detection

Version 1.0.0 | Implementation-ready specification

1. Mission

Implement a uniform enterprise security layer covering human/service identity, authorization, zero trust, tenant isolation, privacy, cryptography, secure delivery, threat detection, incident response and audit/compliance evidence.

2. Phase 27 Alignment

Phase 28 hardens the entire platform, including the Phase 27 AI layer. AI provider/model/tool policies may further restrict access but can never expand a user or service identity beyond ordinary data, tenant and authorization boundaries.

3. Identity & Zero Trust

Default deny, least privilege, MFA/step-up, risk/session context, JIT privileged elevation, service identities and explicit tenant/resource scope are enforced at protected boundaries.

4. Privacy & Data Protection

Data classification drives minimization, retention/deletion, export, encryption and handling requirements according to approved tenant/platform policy.

5. Secrets & Cryptography

Secrets, keys and certificates use managed provider references, ownership, rotation and expiry controls. Plaintext production secrets do not belong in source code or ordinary configuration.

6. Secure SDLC

Source, dependency, container, infrastructure and secret scanning are release gates. Security exceptions are time-bound, owned, evidenced and re-reviewed.

7. Threat Detection & Incident Response

Identity/API/data/AI/infrastructure security events feed normalized telemetry and detection rules. Alerts route to governed incident containment, recovery, forensics and corrective actions.

8. Audit & Compliance

Security-sensitive decisions and privileged actions produce protected audit evidence. Access reviews, SoD, policy attestations and control evidence support enterprise governance.

9. Threat Modeling

Material architecture, data, AI and integration changes are evaluated for threats such as tenant leakage, escalation, credential compromise, prompt injection, supply-chain compromise and audit tampering.

10. Implementation Order

Identity/policy -> tenant isolation -> privileged access -> secrets/keys -> data/privacy -> app/API/file/AI security -> secure SDLC -> telemetry/detection -> incidents -> access reviews/SoD/compliance.

Security Modules

ID	Module	Layer	Purpose
P28-MOD-001	Security Policy Registry	Security Platform	Versioned security policies, owners, applicability, exceptions and approvals
P28-MOD-002	Identity Provider Adapter	Identity	Provider-neutral SSO/OIDC/SAML authentication integration boundary
P28-MOD-003	MFA Policy Service	Identity	Risk/role/tenant-aware MFA requirements and enrollment state
P28-MOD-004	Identity Lifecycle Service	Identity	Joiner/mover/leaver lifecycle and directory/SCIM synchronization
P28-MOD-005	Role Service	Authorization	Governed RBAC roles, permissions and assignment lifecycle
P28-MOD-006	Attribute Policy Service	Authorization	ABAC attributes and conditional access policies
P28-MOD-007	Policy Decision Point	Authorization	Central default-deny policy evaluation
P28-MOD-008	Policy Enforcement Middleware	Authorization	API/service/UI/tool enforcement hooks
P28-MOD-009	Privileged Access Service	Identity	Privileged role elevation, expiry, approval and evidence
P28-MOD-010	Service Identity Registry	Identity	Service/machine identities, ownership, scope and credential rotation
P28-MOD-011	Session Security Service	Identity	Session/device/risk context, expiration, revocation and reauthentication
P28-MOD-012	Tenant Isolation Guard	Zero Trust	Cross-tenant request/data/object/search/cache/event isolation controls
P28-MOD-013	Data Classification Service	Privacy	Classification labels, handling policy and inheritance
P28-MOD-014	Privacy Control Service	Privacy	Purpose, minimization, retention, deletion and export controls
P28-MOD-015	Encryption Policy Service	Cryptography	Required encryption state by data/service classification
P28-MOD-016	Key Management Adapter	Cryptography	Key creation/use/rotation/revocation integration boundary
P28-MOD-017	Secrets Management Adapter	Cryptography	Secrets retrieval, lease/rotation and no-secret-in-source enforcement
P28-MOD-018	Certificate Lifecycle Service	Cryptography	Certificate inventory, expiry, rotation and ownership
P28-MOD-019	API Security Gateway	Application Security	Rate limits, authn/z, validation, replay/idempotency and abuse controls
P28-MOD-020	Event Security Service	Application Security	Publisher/consumer identity, tenant context, schema and replay controls
P28-MOD-021	File/Object Security Service	Application Security	Upload scanning, classification, permission and signed-access controls
P28-MOD-022	Search Security Filter	Application Security	Permission-aware indexing and query result filtering
P28-MOD-023	AI Security Policy Service	AI Security	Approved providers/models/data classes/tools/retention and prompt security policy
P28-MOD-024	Prompt Injection Defense	AI Security	Untrusted-content boundaries, tool policy and instruction isolation
P28-MOD-025	Secure SDLC Gate	DevSecOps	SAST, dependency, secret, IaC, container and license/security gates
P28-MOD-026	Vulnerability Service	DevSecOps	Finding intake, severity, ownership, SLA, exception and closure evidence
P28-MOD-027	Threat Model Registry	Security Engineering	System/data-flow threats, mitigations, owners and review history
P28-MOD-028	Attack Surface Registry	Security Engineering	External/internal assets, exposure, ownership and change monitoring
P28-MOD-029	Security Telemetry Pipeline	SecOps	Normalized security logs/events with correlation and retention
P28-MOD-030	Threat Detection Engine	SecOps	Rule/anomaly detections for identity, tenant, API, data and AI security events
P28-MOD-031	Security Alert Service	SecOps	Alert severity, routing, deduplication, escalation and acknowledgment
P28-MOD-032	Security Incident Service	SecOps	Triage, containment, evidence, communication, recovery and closure
P28-MOD-033	Forensic Evidence Service	SecOps	Preserve security evidence chain, hashes and access history
P28-MOD-034	Access Review Service	Governance	Periodic role/privileged/service-account access certification
P28-MOD-035	Segregation of Duties Engine	Governance	Detect/deny or review incompatible role/action combinations
P28-MOD-036	Compliance Evidence Service	Governance	Control-to-evidence mappings and policy attestations

ID	Module	Layer	Purpose
P28-MOD-037	Security Exception Service	Governance	Risk acceptance, compensating controls, expiry and renewal
P28-MOD-038	Security Metrics Service	Governance	Control coverage, vulnerability, identity, incident and detection KPIs
P28-MOD-039	Security Admin Console	Operations	Restricted administration, configuration and emergency controls
P28-MOD-040	Security Digital Twin	Operations	Current identity, policy, exposure, findings, alerts, incidents and control state

Threat Model Register

ID	Threat	Severity	Primary Controls
TM-001	Cross-tenant data leakage	Critical	Tenant context enforcement + negative tests + data partition/filter controls
TM-002	Privilege escalation	Critical	Default deny + approval + MFA + SoD + audit
TM-003	Stolen session/token	High	Short-lived tokens + revocation + step-up + anomaly detection
TM-004	Service credential compromise	Critical	Managed secrets + scoped identity + rotation + kill/revoke
TM-005	Prompt injection/tool abuse	High	Instruction isolation + tool policy + human approval + adversarial eval
TM-006	API abuse/replay	High	Validation + rate limit + idempotency + replay controls
TM-007	Malicious file upload	High	Type validation + scanning + sandboxing + permission controls
TM-008	Audit tampering	Critical	Append-oriented protected audit + restricted admin + external evidence/monitoring
TM-009	Supply-chain compromise	Critical	Pin/scan/sign/provenance + controlled build/promotion
TM-010	Secret leakage in logs	High	Structured logging policy + redaction + scanning/tests
TM-011	Search inference leakage	Medium	Permission-aware indexing/results/counts/snippets
TM-012	Backup exposure	High	Encrypted backups + restricted restore + access audit
TM-013	Insider privilege misuse	High	JIT elevation + MFA + monitoring + SoD + periodic review
TM-014	Ransomware/destructive admin	Critical	Least privilege + immutable backups + break-glass controls + alerting
TM-015	AI provider data exposure	High	Provider/data-classification policy + redaction + audit
TM-016	Configuration drift	High	IaC/config drift detection + policy-as-code + alerting